

BANCA POR INTERNET

Arquitectura de solución para BP

La propuesta mantiene al Core como autoridad financiera y separa los canales, la integración y los procesos de soporte. Una transferencia conserva la misma identidad durante sus reintentos, conciliación y notificación.

Se plantea una SPA y una aplicación móvil multiplataforma, integradas con el servicio de identidad existente. Los servicios de Clientes, Movimientos y Transferencias/Pagos concentran las capacidades solicitadas. Onboarding, auditoría y notificaciones completan los controles del canal.

El diseño utiliza AWS, tres zonas de disponibilidad y una segunda región de recuperación. Las decisiones se acompañan de alternativas, fundamentos y límites verificables.

Lectura del documento

Bloque	Contenido
Alcance y estructura	Supuestos, contexto, contenedores y componentes C4.
Flujos y datos	Canales, autenticación, onboarding, transferencias, caché y auditoría.
Operación y decisiones	Seguridad, Ecuador, despliegue, continuidad, costos y justificaciones.
Verificación	Trazabilidad de requisitos, criterios de aceptación y fuentes.

Documento de diseño. Los objetivos y las pruebas descritos no constituyen resultados de una implementación desplegada.

01 / Alcance y supuestos

Capacidades incluidas

Consultar datos básicos y detalles del cliente, productos e histórico de movimientos; transferir y pagar entre cuentas propias e interbancarias; incorporar nuevos clientes desde el móvil con verificación facial; autenticar ambos canales; registrar acciones del cliente y comunicar sus movimientos por al menos dos sistemas de notificación.

Supuestos que condicionan el diseño

ID	Supuesto o decisión de alcance
S1	BP opera en Ecuador. El Core conserva clientes básicos, productos, saldos y asientos; el sistema complementario entrega el detalle adicional.
S2	El Core ofrece una operación atómica para transferencias propias y permite consultar operaciones por referencia única. Se debe confirmar su soporte de idempotencia antes de habilitar escrituras.
S3	La red interbancaria dispone de referencia de operación, consulta de estado y confirmaciones autenticadas. El Core administra reserva, débito y reverso. No se presupone liquidación instantánea.
S4	El producto de identidad existente permite OAuth 2.0. Se verificará OIDC, PKCE, MFA, revocación, eventos de auditoría y alta administrativa. No se sustituye ni se desarrolla otro IdP.
S5	No se han suministrado contratos, carga, latencias, regiones autorizadas ni presupuesto numérico. Las cifras de capacidad y recuperación son objetivos de diseño sujetos a validación.
S6	Pagos significa pagos mediante cuentas y el riel bancario descrito. No se añade adquirencia de tarjetas, préstamos, inversiones ni un nuevo Core.

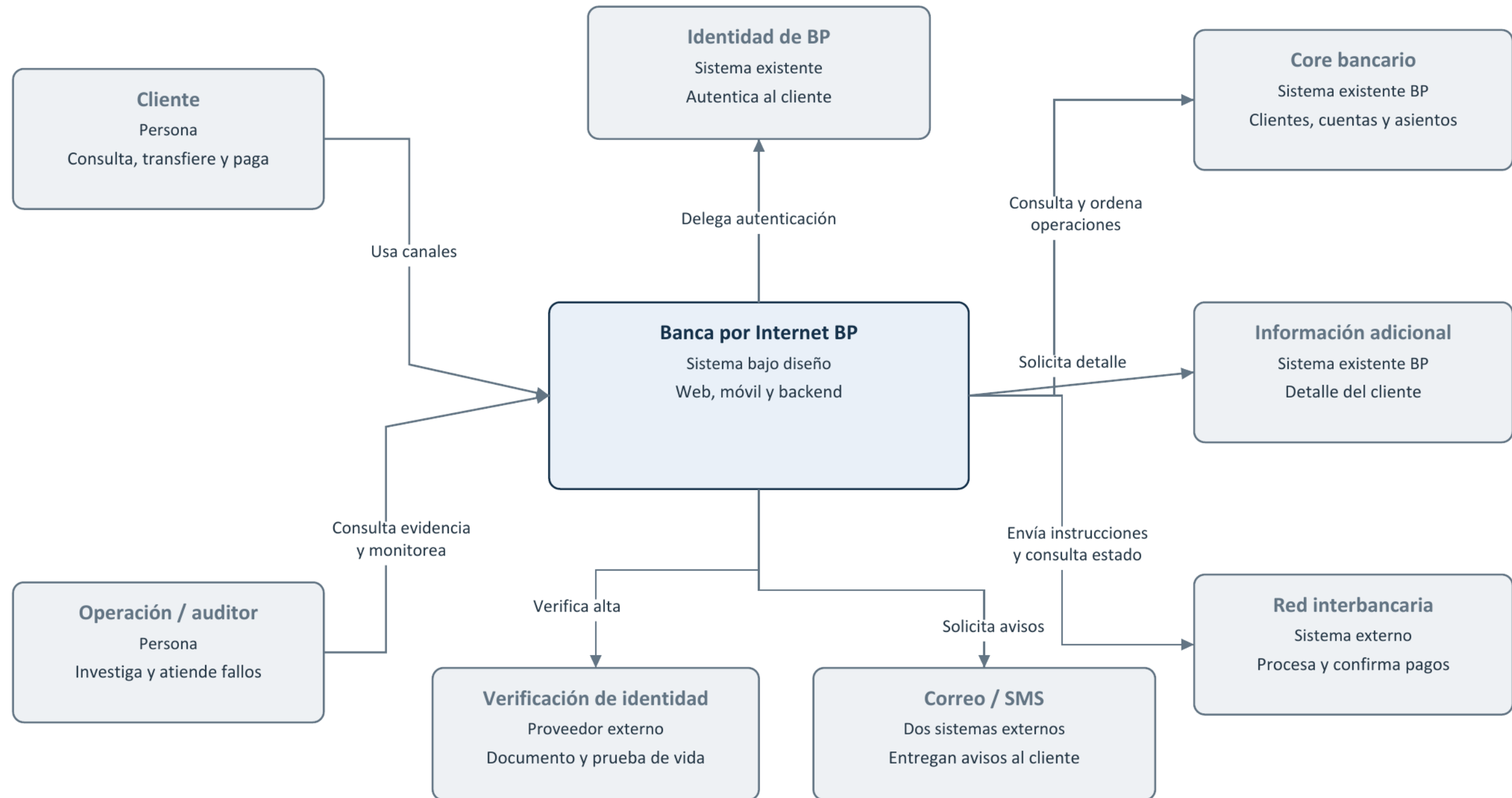
Entregable

PDF con diagramas C4 de contexto, contenedores y componentes; flujos de autenticación y transferencias; despliegue y decisiones. No se requiere código de una aplicación ni un diagrama C4 de nivel 4.

Convención: azul = solución BP; gris = persona o sistema externo al alcance; verde = datos o mensajería. Las flechas indican quién inicia la interacción. Una línea discontinua representa publicación o consumo asíncrono. [01]

02 / C4 - Contexto

Vista para negocio: actores, sistema bajo diseño y relaciones con su entorno. [01]

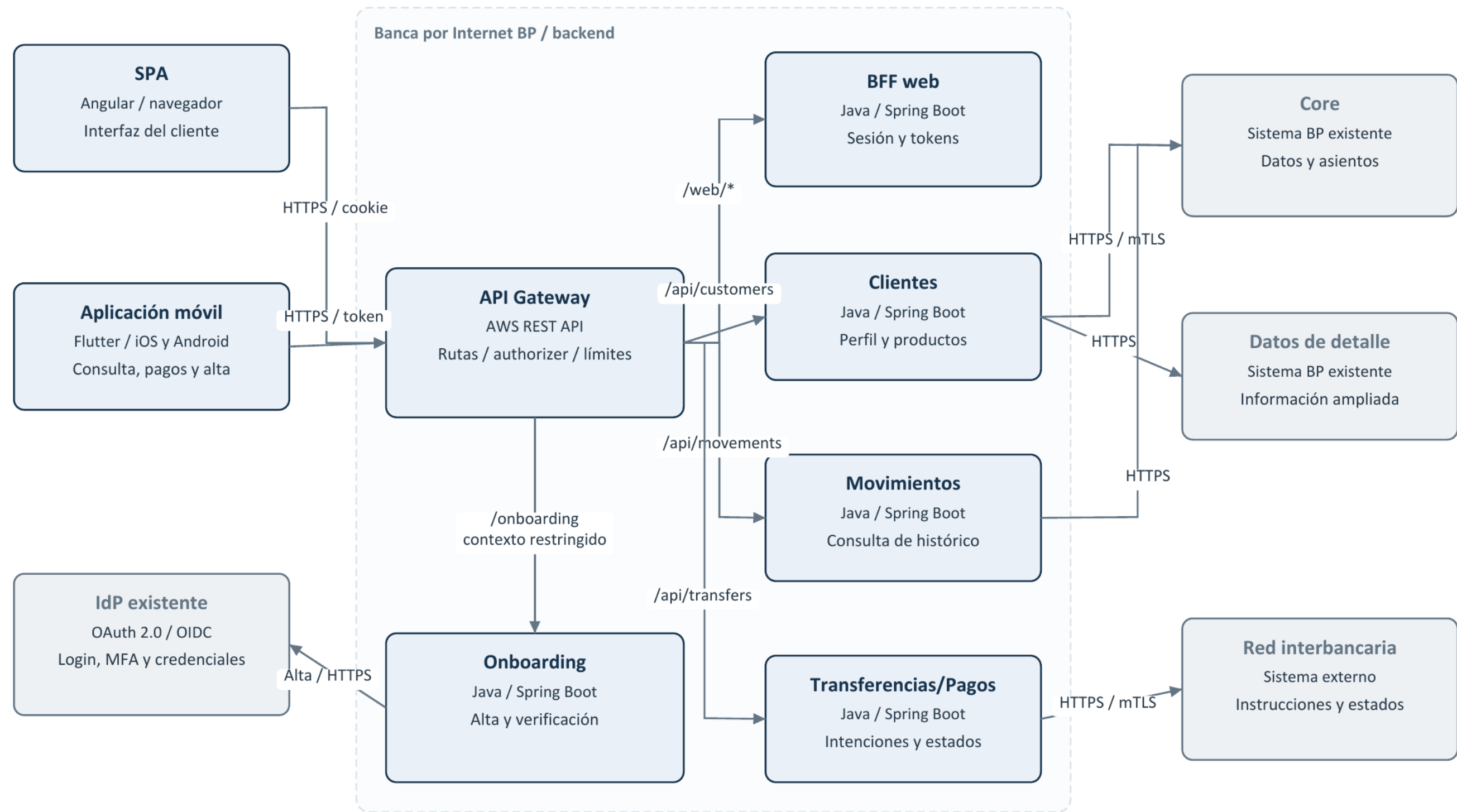


Límite: el sistema BP diseñado no reemplaza Core, identidad, red interbancaria ni sistemas de notificación.

El límite de Banca por Internet incluye ambos canales y su backend. Core, identidad y datos complementarios son sistemas existentes de BP; la red interbancaria y los proveedores son dependencias externas. Operación utiliza las herramientas corporativas de monitoreo y auditoría.

03 / C4 - Contenedores de atención

Contenedores lógicos. Las réplicas, zonas y redes se describen en el despliegue.



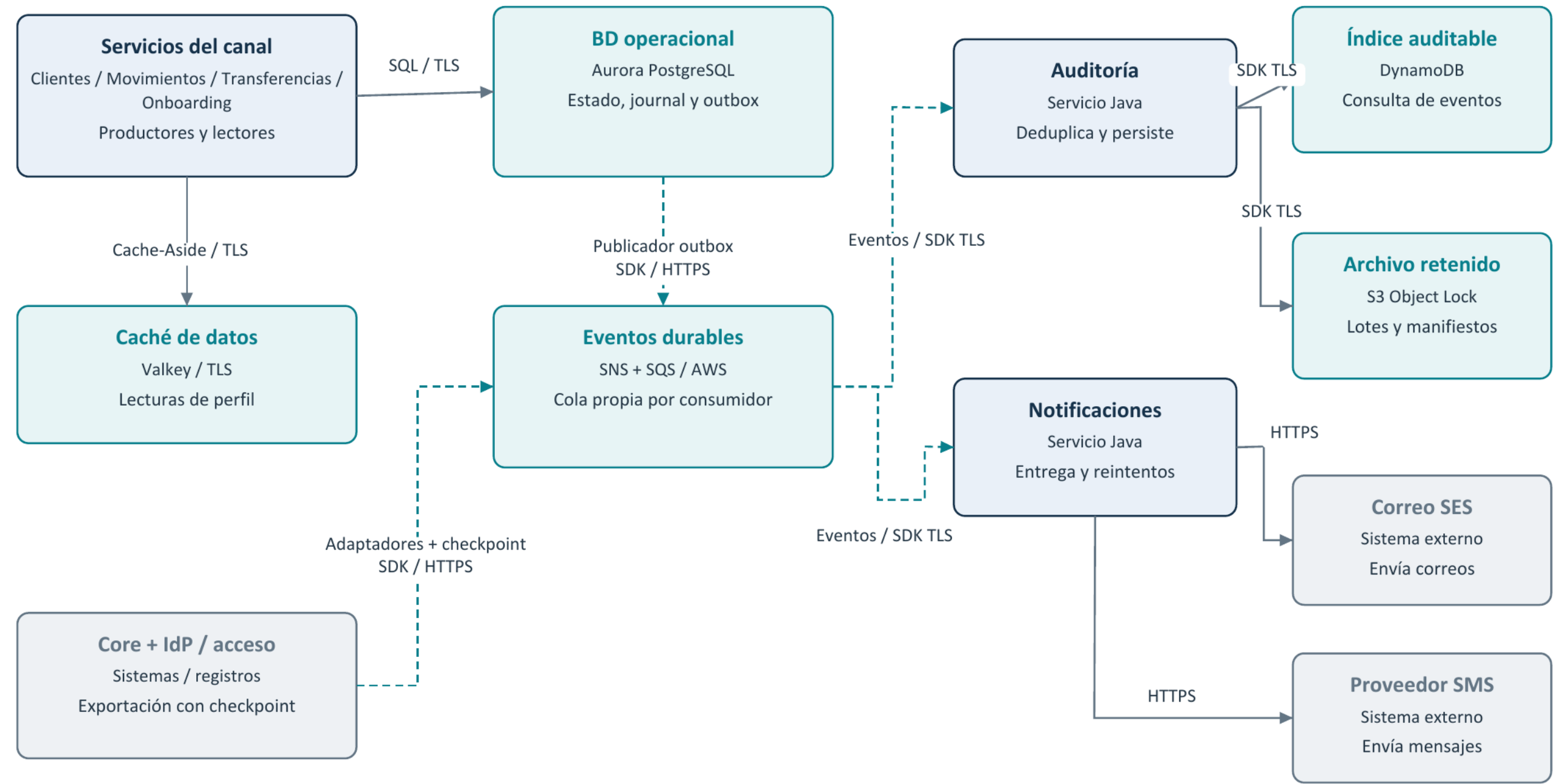
BFF y móvil usan OIDC con el IdP (secuencia de acceso). BFF llama a los tres servicios con token delegado / HTTPS. Transferencias también invoca Core. Datos: C2 de soporte.

API Gateway es la puerta de integración. El BFF atiende la sesión web; el móvil presenta su access token. Los servicios conservan sus responsabilidades y contratos. La mensajería y los consumidores se amplían en la siguiente vista del mismo sistema.

04 / C4 - Contenedores de soporte

Ampliación del C2: datos, eventos, auditoría y dos proveedores de notificación.

C2 ampliado: azul/verde = solución BP; gris = sistemas externos al alcance.



No mostrados: Valkey exclusivo de sesiones del BFF y S3 exclusivo de evidencia de Onboarding. Notificaciones posee esquema de entregas; cada cola tiene DLQ.

Los outbox de los servicios y los eventos del Core alimentan canales durables. Auditoría y Notificaciones consumen copias independientes del evento. Los productores conservan la capacidad de republicar; cada consumidor deduplica por eventId.

05 / Contratos y responsabilidades

Contenedor	Responsabilidad y límite
SPA / móvil	Presentación, captura y confirmación. No calcula el saldo disponible ni autoriza una cuenta por ocultar botones.
BFF web	Cliente OAuth confidencial, cookies y tokens en servidor. Compone respuestas de presentación, sin reglas contables.
API Gateway REST	Rutas, límites, validación básica, correlación y Lambda authorizer para access tokens del IdP externo en /api/*.
Clientes	Agrega datos básicos del Core y detalle del sistema complementario. Controla caché por cliente y responde con procedencia y fecha.
Movimientos	Consulta paginada al Core. Verifica titularidad, período y cursor; no copia el libro contable.
Transferencias/Pagos	Valida intención, límites y autorización; persiste estado; llama al Core o a la red y concilia resultados inciertos.
Onboarding	Coordina evidencia, revisión de identidad y alta. Una sesión de registro no concede permisos de banca.
Auditoría / Notificaciones	Persisten trazas de negocio y estados de entrega. Un fallo de correo no cambia el resultado financiero.

Integración y seguridad del contrato

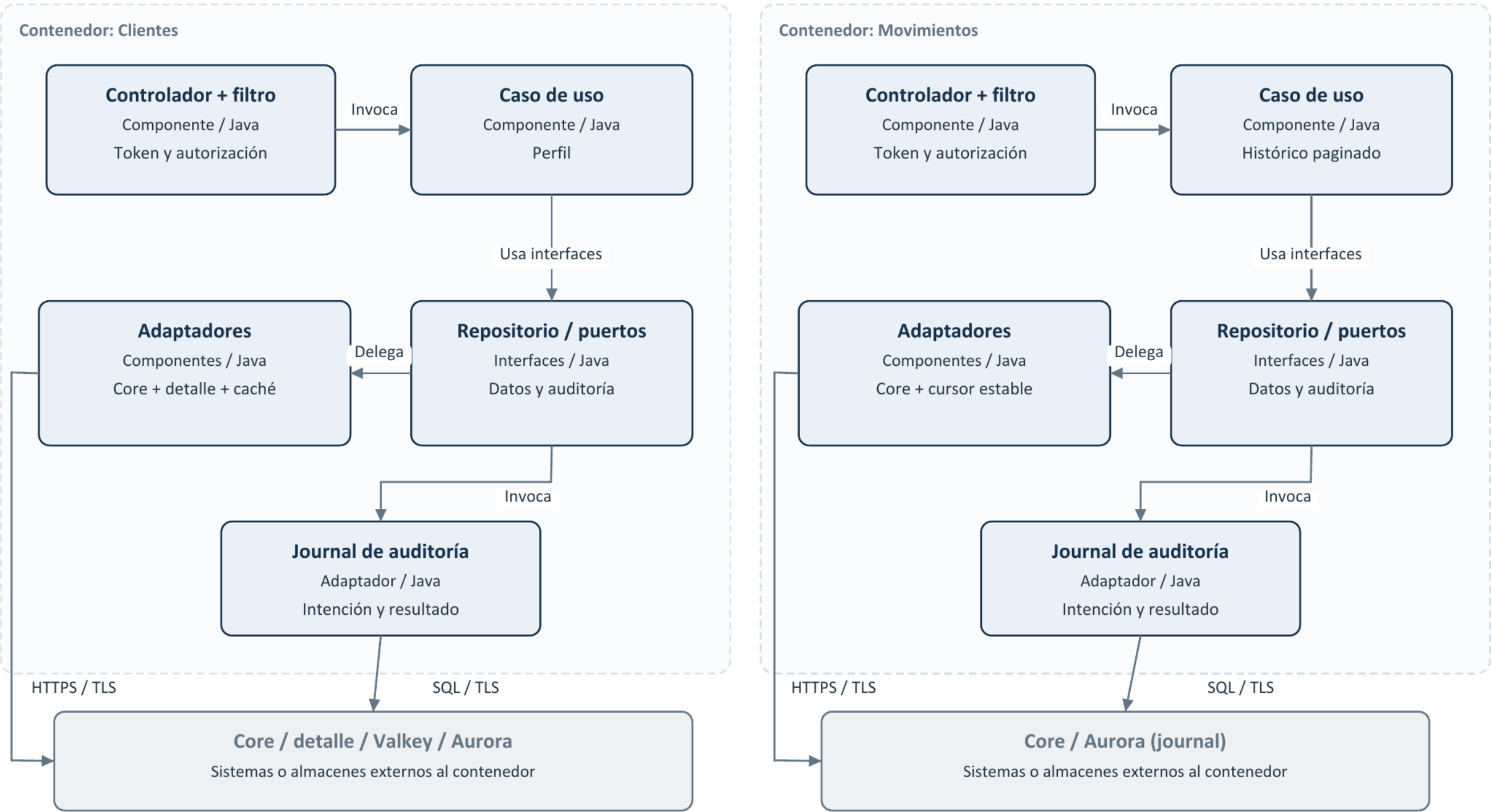
REST/JSON sobre HTTPS para consultas y comandos. OpenAPI versionado y errores con código estable, correlationId y descripción sin datos sensibles. mTLS y credenciales de servicio para Core, red y detalle cuando sus contratos lo permitan; adaptadores traducen SOAP o formatos legados sin filtrarlos al dominio.

Cada servicio valida la firma o introspección del access token, issuer, audiencia y permisos, además de la titularidad del recurso. El authorizer no reemplaza la autorización de negocio. El IdP publica claves con rotación; claves desconocidas o tokens inválidos fallan de forma cerrada.

En /web/* el Gateway enruta al BFF: éste valida cookie, CSRF y sesión; /api/* exige access token. Las rutas de onboarding admiten sólo el contexto temporal de registro. [02][03][10]

06 / C4 - Componentes de consulta

C3 de Clientes y Movimientos. Componentes Java / Spring Boot; dependencias internas por interfaces.

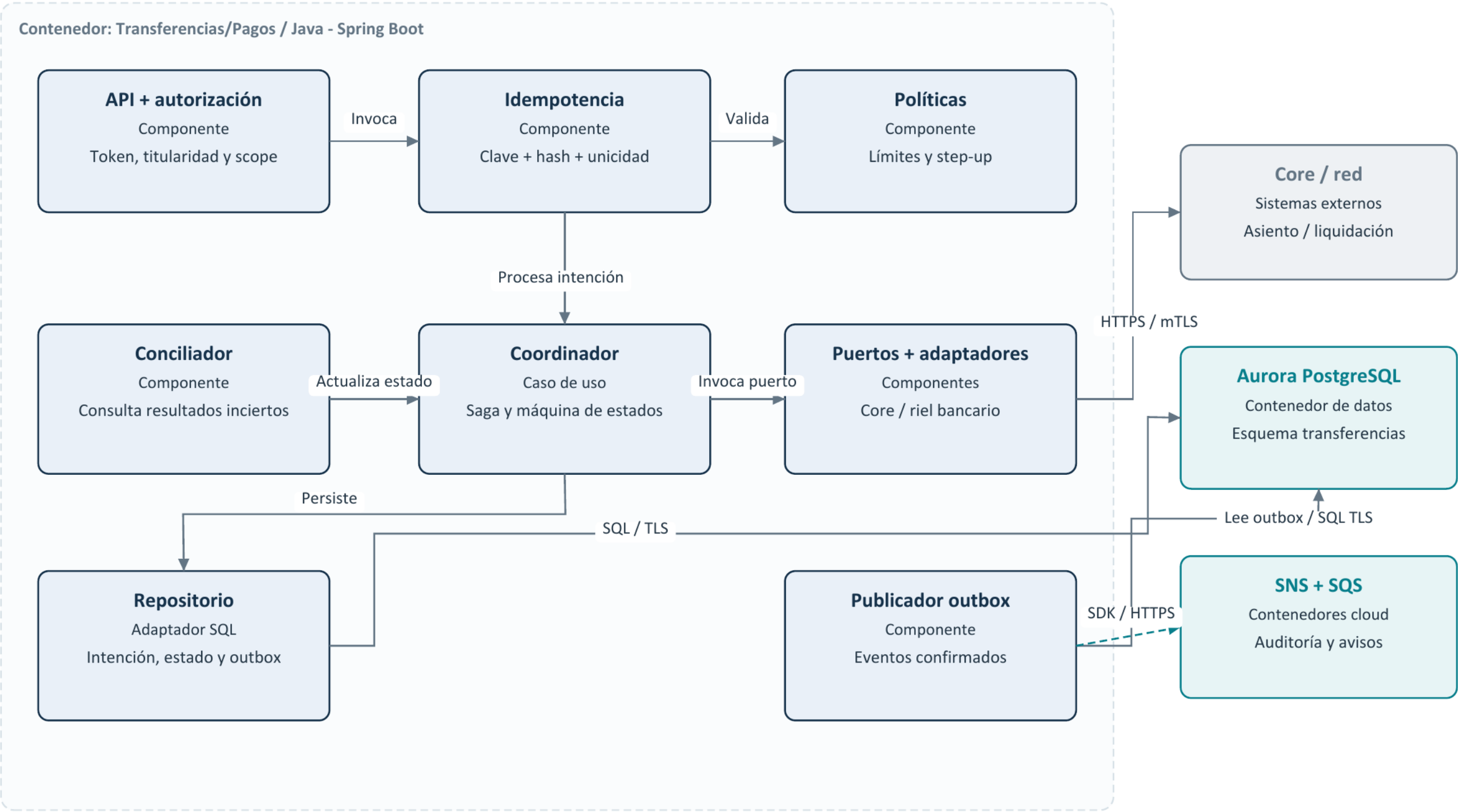


Las dependencias de dominio apuntan a interfaces. Core y detalle se consultan por adaptadores; el journal se publica posteriormente al canal de auditoría.

Cada recuadro delimita un único contenedor. Controladores y filtros reciben solicitudes; casos de uso aplican autorización; puertos y adaptadores aíslan Core, detalle y caché. La persistencia de auditoría no depende del caché.

07 / C4 - Componentes de transferencias

C3 de Transferencias/Pagos: idempotencia, orquestación, persistencia y recuperación.

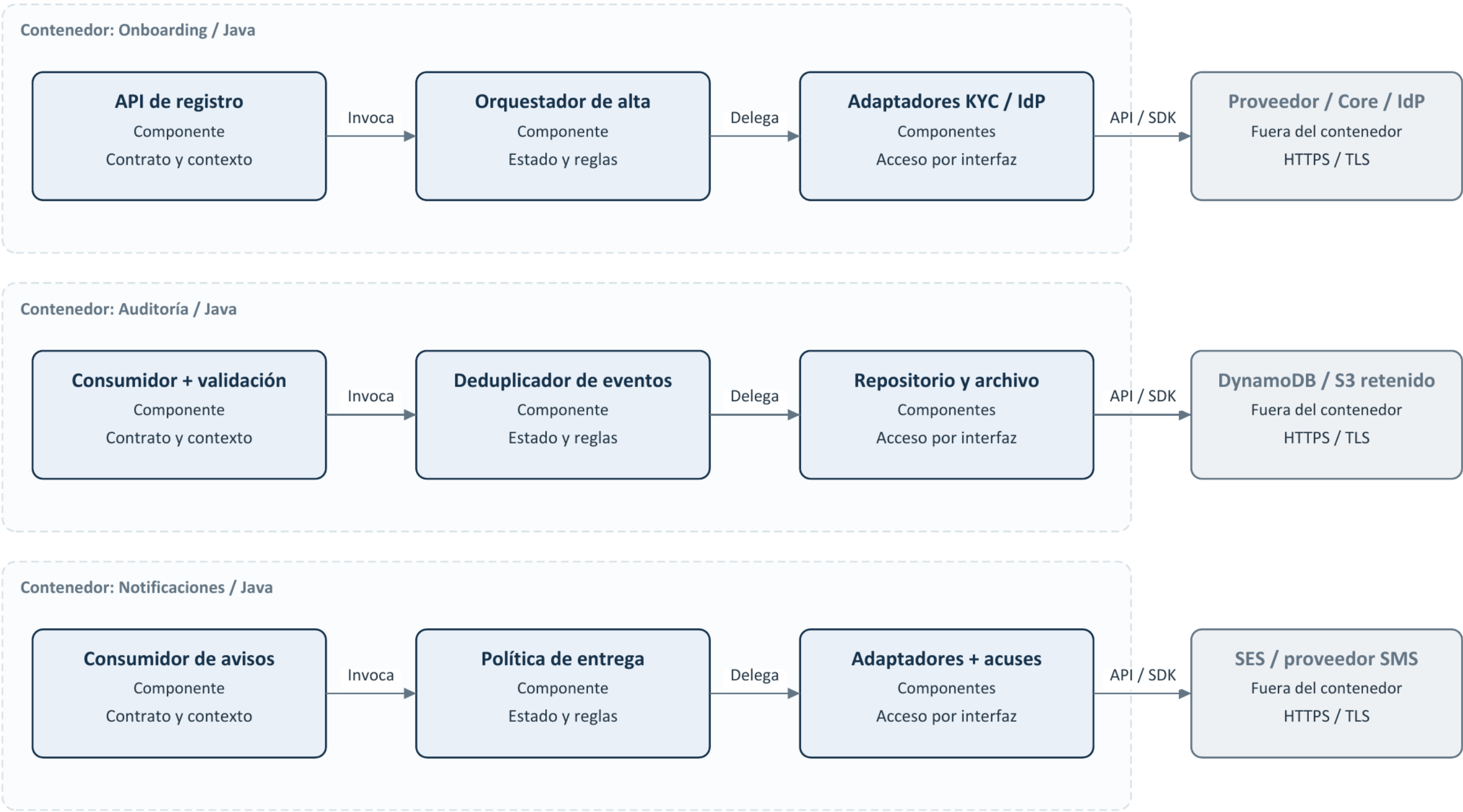


La transacción SQL sólo cubre los datos locales. Antes de llamar al Core se conserva la referencia externa; la conciliación y el fencing limitan duplicados.

El repositorio persiste la intención antes del envío externo. El coordinador usa una máquina de estados y referencias estables; el conciliador consulta resultados inciertos. Los adaptadores implementan los contratos financieros, sin suponer una transacción distribuida con el Core.

08 / C4 - Componentes de soporte

C3 de Onboarding, Auditoría y Notificaciones. Cada servicio tiene persistencia propia o un esquema de acceso exclusivo.



Persistencia: Onboarding guarda expediente/estado; Notificaciones guarda intentos e idempotencia; Auditoría guarda índice y evidencia. El detalle de esos almacenes está en C2.

Onboarding combina resultado biométrico y verificación de identidad antes de activar un cliente. Los otros dos límites muestran los componentes de Auditoría y Notificaciones. Los adaptadores permiten cambiar proveedores sin modificar sus casos de uso.

09 / Arquitectura web y móvil

Canal	Alternativas y elección
SPA	Angular frente a React. Se elige Angular: sus convenciones reducen variaciones entre módulos y sus formularios/enrutamiento permiten una estructura común. React es válido con un equipo especializado, pero exige acordar más piezas de arquitectura. [06]
Móvil	Flutter frente a React Native. Se elige Flutter: una base compartida facilita consistencia entre iOS/Android y MVVM permite separar vistas, estado y repositorios. React Native aprovecha experiencia React y componentes nativos; sería preferible si esa experiencia predomina. [07][08]

Separación dentro de los canales

SPA: módulos de acceso, clientes, movimientos y transferencias. Componentes de vista llaman a fachadas de presentación; éstas usan un cliente HTTP al BFF. Formularios tipados validan formato; las reglas y permisos se vuelven a comprobar en el backend. Carga diferida por ruta y política de seguridad de contenido estricta.

Móvil: vistas y ViewModels, casos de uso donde la coordinación lo justifique, repositorios y adaptadores de API/almacenamiento seguro. Onboarding integra cámara y el SDK biométrico mediante un adaptador. Se debe validar el puente a SDK nativo del proveedor en ambos sistemas; no se presupone que exista soporte Flutter directo. [07][14]

Estado sensible y experiencia de uso

La SPA conserva una cookie de sesión opaca HttpOnly, Secure y SameSite; no guarda tokens en localStorage. La app conserva secretos sólo en almacenamiento del sistema protegido por hardware cuando esté disponible. Cerrar sesión borra datos temporales y revoca la sesión.

Una operación enviada no se vuelve a crear al perder conexión: la interfaz consulta su estado. Las pantallas distinguen pendiente, completada y rechazada. No hay transferencias fuera de línea. El histórico incluye fecha de actualización, filtros acotados y paginación.

La huella o rostro del dispositivo puede desbloquear una credencial. Ese desbloqueo local, por sí solo, no demuestra al servidor quién es el cliente: se exige la prueba criptográfica o el flujo del IdP.

10 / Autenticación y autorización

Flujo elegido

OAuth 2.0 delega autorización; OIDC aporta la identidad autenticada. Se utiliza Authorization Code con PKCE S256. Se descartan Implicit y Resource Owner Password Credentials. Cada cliente tiene su registro, redirect URI exacta y permisos mínimos. state y nonce se vinculan a la sesión y se validan una sola vez. [02][03]

En web, el BFF realiza el intercambio y almacena tokens del lado servidor; la SPA usa cookie y protección CSRF con comprobación de Origin. En móvil se abre el navegador del sistema y se retorna mediante enlaces de aplicación verificados. El móvil es cliente público y no contiene un secreto OAuth. [04]

Sesión y permisos propuestos

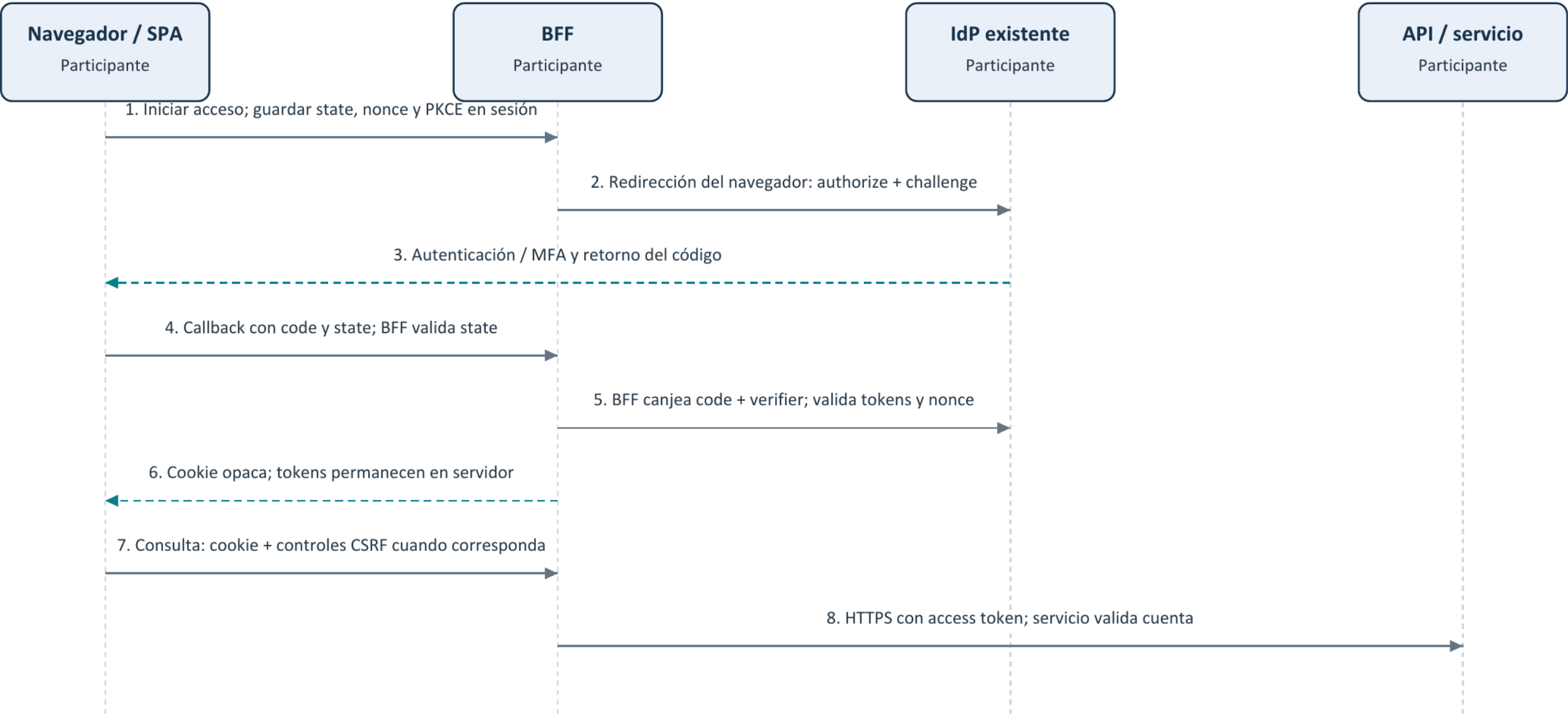
Control	Aplicación
Access token	Vida corta inicial de 5 minutos; validar firma, algoritmo permitido, issuer, aud, exp y scopes. Nunca enviar el ID token como credencial de la API.
Refresh y cierre	Rotación y detección de reutilización, si el IdP lo admite. BFF serializa refrescos por sesión. Revocación y límites iniciales de 10 minutos inactivo / 8 horas absoluto, ajustados por riesgo.
Scopes	customers:read, movements:read, transfers:create y transfers:read. Comprobar sub-cliente-cuenta en el servicio incluso con un scope válido.
MFA / step-up	Passkey con verificación del usuario, si el producto lo soporta; alternativa contraseña más segundo factor. La confirmación de transferencia vincula importe, moneda, destino y nonce de un solo uso.

El IdP solicita la autenticación reforzada y el backend comprueba su antigüedad y nivel. Un cambio de importe o beneficiario invalida la autorización de la intención. Los webhooks externos requieren firma, ventana temporal y deduplicación; el clientId OAuth no sirve de identidad financiera.

Los tiempos de sesión son parámetros propuestos, no requisitos extraídos del enunciado. WebAuthn ofrece credenciales de clave pública ligadas al servicio; no transfiere la huella del dispositivo al banco. [05]

11 / Secuencia de acceso

Authorization Code + PKCE; identidad mediante OIDC. [02][03][04]



Móvil: app -> navegador del sistema -> IdP -> enlace verificado -> app. La app canjea code + verifier, protege los tokens y llama a /api/* con access token.

La parte superior muestra el acceso web. La inferior muestra la diferencia del móvil: PKCE y tokens se gestionan en el cliente nativo con su navegador externo. En ambos casos el servicio comprueba el recurso solicitado.

12 / Onboarding facial y activación

Proceso propuesto

- 1. Inicio:** la app solicita una sesión de onboarding corta, vinculada a instalación y nonce. El backend registra finalidad, versión del aviso y base jurídica validada. La sesión sólo permite completar ese registro; no usa scopes bancarios.
- 2. Evidencia:** captura guiada del documento y prueba de vida. El backend genera credenciales de captura de duración y alcance mínimos o una URL de carga limitada; comprueba tamaño, tipo, sesión y vencimiento. Se almacena evidencia cifrada y separada de los datos operativos.
- 3. Validación:** el adaptador consulta el resultado directamente al proveedor, compara identidad documental y rostro y aplica controles KYC existentes de BP. Nunca confía en un booleano enviado por la app. Liveness detecta presencia; no sustituye documento, listas de control ni la evaluación de riesgo. [14]
- 4. Resolución:** resultados inconclusos o inconsistentes pasan a revisión humana. Se ofrece una vía asistida alternativa. Los umbrales y tasas de falso rechazo/aceptación se validan con una muestra representativa, sin asumir precisión perfecta.
- 5. Activación:** alta idempotente en Core y vinculación en IdP mediante cuenta técnica restringida. Si uno falla, queda PENDIENTE_ACTIVACION y se reanuda; no se emite acceso bancario hasta que ambos confirman el mismo vínculo cliente-subject.
- 6. Accesos posteriores:** el usuario registra una passkey o configura contraseña y MFA en el IdP. Recuperar una cuenta exige verificación equivalente; un correo o SMS por sí solo no habilita sustitución de credenciales.

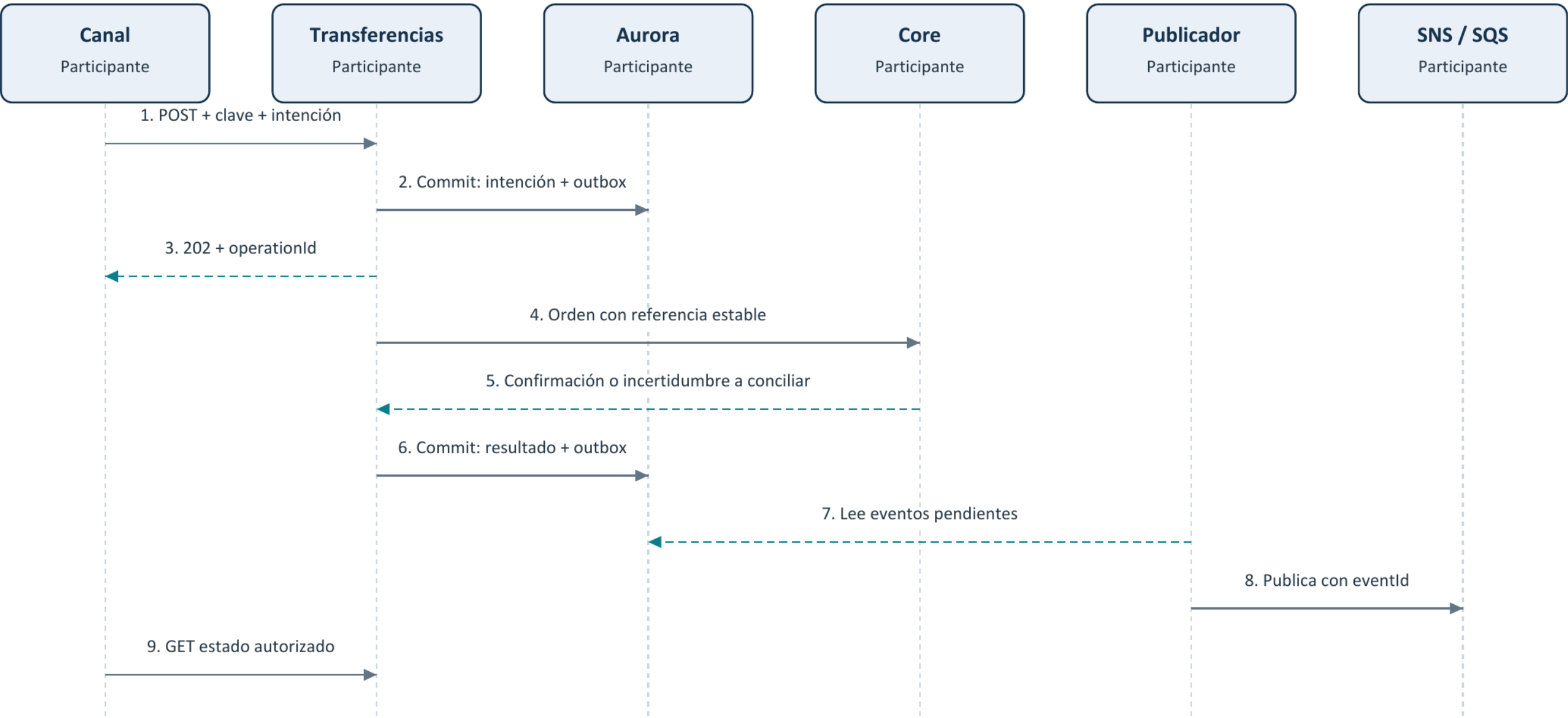
Proveedor y privacidad

Rekognition Face Liveness y comparación facial son una opción técnica, condicionada a región autorizada, SDK, evaluación de impacto y proceso documental complementario. Un proveedor KYC especializado con soporte documental ecuatoriano es alternativa a evaluar mediante pruebas y contrato. [14]

El expediente retiene sólo la evidencia necesaria durante el plazo aprobado por Cumplimiento. No se copian imágenes faciales en logs, caché, notificaciones ni en la base de auditoría.

13 / Secuencia de una transferencia

Recorrido con idempotencia, confirmación financiera y publicación posterior de eventos.



Los eventos generan auditoría y avisos. Una caída entre el commit del Core y el local exige conciliación; el outbox no hace atómica esa frontera.

El ejemplo corresponde a una transferencia propia. La transacción local guarda intención, estado y outbox; la operación financiera pertenece al Core. Un timeout no implica rechazo: se consulta por la misma referencia antes de decidir un reenvío.

14 / Transferencias y pagos

Identidad estable de una operación

POST /v1/transfers recibe Idempotency-Key, cuentas referenciadas, moneda e importe decimal en texto. El servicio deriva el cliente de la identidad autenticada. Una restricción única (cliente, clave) y un hash canónico del cuerpo impiden dos intenciones: mismo cuerpo devuelve la misma operación; otro cuerpo produce 409. La clave y la referencia externa se conservan durante el horizonte máximo de conciliación.

Antes de responder 202 se persiste la intención con auditoría/outbox. GET /v1/transfers/{id} sólo es accesible por su titular. Un 202 significa aceptada para procesamiento; COMPLETADA sólo se informa después de la confirmación financiera. El Core valida saldo disponible y realiza el asiento; un valor en caché nunca habilita un débito.

Estado	Transición y evidencia
RECIBIDA	Intención persistida. Pasa a VALIDADA con titularidad, límites y confirmación vinculada. Falla de negocio: RECHAZADA.
ENVIADA	Referencia externa persistida antes de invocar Core/red. Respuesta verificable produce COMPLETADA, PENDIENTE o RECHAZADA.
DESCONOCIDA	Timeout o caída tras el envío. El conciliador consulta la referencia. No crea otra operación ni la marca fallida por tiempo transcurrido.
PENDIENTE	Interbancaria aceptada, pendiente de liquidación. Callback firmado o consulta autenticada avanza el estado.
EN_REVERSO / REVERTIDA	Rechazo definitivo posterior a reserva/débito inicia compensación en Core. Sólo se declara REVERTIDA tras confirmación del reverso.

Interbancarias: saga con conciliación

El coordinador solicita reserva en Core, envía la instrucción con referencia estable y finaliza el débito al confirmar liquidación, según el contrato del riel. Un rechazo definitivo libera la reserva o solicita reverso. La compensación es otra operación financiera idempotente; no es un rollback de base de datos. Incertidumbre prolongada escala a Operaciones con la evidencia y sigue conciliándose.

Condición de salida a producción: Core y red deben ofrecer idempotencia durable o consulta inequívoca por referencia con semántica acordada. Sin ella no se promete ejecución única. Versionado optimista evita transiciones concurrentes incompatibles.

15 / Acceso a datos y clientes frecuentes

Almacén	Propiedad, consistencia y uso
Core / sistema de detalle	Fuentes de verdad financieras y de perfil, respectivamente. El canal conserva referencias, no un segundo libro de saldos.
Aurora PostgreSQL	Estado de transferencias, onboarding, entregas, outbox y journal de auditoría. Esquemas y usuarios exclusivos por servicio; sin consultas cruzadas. Un clúster inicial reduce costo, pero comparte el dominio de fallo.
Valkey de datos	Caché de perfil/productos no sensibles para lecturas frecuentes; TTL inicial de 60 s con dispersión. No decide titularidad, permisos, límites ni fondos.
Valkey de sesiones	Almacén separado del BFF, con ACL y cifrado. Pérdida del almacén exige reautenticación; no se reconstruye una sesión desde el caché de perfiles.
DynamoDB de auditoría	Índice de eventos por actor/fecha y operación; eventId único. La evidencia de retención se preserva también en S3 con Object Lock.
S3 de evidencias	Expedientes de onboarding aislados de auditoría. Retención y acceso por finalidad; objetos cifrados y referencias no públicas.

Repository + Cache-Aside + invalidación

Clientes autoriza primero y consulta su repositorio. Con acierto devuelve perfil y asOf; con fallo lee Core y, sólo si se solicitó detalle, el sistema complementario, y repuebla. Una actualización confirmada invalida las claves afectadas mediante evento; TTL limita la antigüedad si se pierde esa señal. Coalescer solicitudes por clave y limitar concurrencia evita una avalancha al Core.

Movimientos consulta por cursor estable (fecha e identificador), acota período y orden, y no usa caché compartido para datos financieros recientes. Si el detalle falla, se devuelve explícitamente respuesta parcial para perfil; si falla el Core, no se presenta un saldo almacenado como actual.

La persistencia durable permanece en los sistemas fuente y Aurora. La caché es un mecanismo de rendimiento recuperable, no reemplaza la persistencia ni garantiza información actualizada.

16 / Auditoría y notificaciones

Trazabilidad de cada acción de negocio

Se registran inicio/cierre de sesión, onboarding, consultas, intentos de acceso, creación y cambios de estado de operaciones y entregas. El evento contiene eventId, actor seudonimizado, acción, recurso referenciado, resultado, hora UTC, canal, correlationId y versión. Se excluyen credenciales, tokens, números completos e imágenes.

Una mutación graba su evento en el outbox dentro de la misma transacción local. Las consultas registran inicio y resultado en un journal durable del servicio antes de revelar datos al cliente. Si ese registro no puede persistirse, se rechaza la consulta. Denegaciones del Gateway y eventos del IdP se exportan con checkpoint; se vigilan huecos y desfases. Esto requiere confirmar la capacidad de exportación del IdP.

El publicador reintenta hasta obtener confirmación del broker, sin borrar la historia de eventos antes de su horizonte de recuperación. Auditoría deduplica y escribe un índice consultable y objetos con retención bloqueada en una cuenta separada. Un manifiesto firmado por lote y verificación de hashes detecta alteraciones; acceso de lectura y administración se audita. Object Lock no evita eventos ausentes: se concilian conteos e identificadores por productor. [09][13]

Dos sistemas de notificación

Se propone Amazon SES para correo y un proveedor SMS independiente contratado por BP. El servicio aplica Adapter y Strategy para seleccionar canal y registrar cada intento. Se envían avisos en ambos canales para movimientos configurados; la política legal y las preferencias determinan el contenido. El Core alimenta además los movimientos originados fuera de estos canales mediante eventos/CDC o una consulta incremental con checkpoint.

Se deduplica por (movimiento canónico, versión de estado, canal), correlacionando la referencia Core con la del canal. SNS distribuye a colas SQS separadas; reintentos con espera creciente y límite, DLQ y alarma evitan pérdida silenciosa. El consumidor distingue aceptado por proveedor, entregado y fallido. Los acuses se validan y se deduplican. [15]

Un fallo de notificación no revierte un movimiento confirmado. Si el proveedor no admite idempotencia ni consulta de estado, un timeout de envío puede causar un aviso duplicado; se reduce ese riesgo sin prometer entrega exactamente una vez.

17 / Seguridad de extremo a extremo

Superficie	Controles y responsabilidad
Borde	WAF en CloudFront y API Gateway REST; TLS 1.2 o superior, rate limits por identidad/ruta, protección de abuso del onboarding y reglas de tamaño. CloudFront sólo cachea recursos estáticos, nunca respuestas bancarias.
Identidad	IdP existente con MFA y recuperación controlada. Sesiones de corta exposición, revocación, protección CSRF/XSS, redirecciones exactas y permisos por recurso.
Red privada	Servicios sin IP pública, ALB interno y grupos de seguridad entre capas. VPC endpoints para servicios compatibles; salida a proveedores mediante NAT redundante y destinos controlados.
Servicios y datos	TLS en cada salto; mTLS entre servicios cuando se configure mediante sidecars y certificados rotados. IAM por tarea, cifrado KMS, Secrets Manager, usuarios de base de datos por servicio y validación de entradas.
Operación	Cuentas separadas para producción, respaldo y auditoría. Roles temporales, MFA de administradores, segregación de funciones y acceso de emergencia con registro y revisión.
Cadena de entrega	Revisión de cambios, análisis de dependencias y secretos, imágenes firmadas, SBOM, pruebas de contrato, autorización y fallos, y despliegue con rollback.

Amenazas concretas y respuesta

Acceso a otra cuenta: autorización por objeto en cada servicio. **Repetición de una orden:** clave idempotente y desafío transaccional consumible. **Suplantación en alta:** documento, prueba de vida, validación del proveedor y revisión humana. **Filtración en trazas:** lista permitida de campos, enmascaramiento y pruebas sobre los logs.

Se definen procedimientos para revocar una credencial, bloquear una integración y aislar un consumidor sin detener consultas sanas. Seguridad revisa amenazas y pruebas de penetración antes del lanzamiento. La configuración de nube no implica por sí sola cumplimiento ni invulnerabilidad.

18 / Marco normativo de Ecuador

Referencia consultada el 15 de septiembre de 2026. La aplicabilidad y los plazos se validan con Cumplimiento y el delegado de protección de datos.

Referencia	Consecuencia para la solución
LOPDP y Reglamento [17][18]	Inventario de tratamientos, base jurídica por finalidad, minimización, derechos del titular y evaluación de impacto. BP define los plazos de conservación y contratos con encargados. La retención legal limita la eliminación cuando corresponda.
SB: riesgo operativo [19]	El art. 17 exige 99,99 % anual para servicios críticos. Se necesitan continuidad, incidentes, gestión de terceros y controles de seguridad respaldados por evidencia. La contratación cloud debe pasar la revisión normativa y contractual de BP.
Transferencias de datos [20]	Validar las garantías aplicables para países, regiones, subencargados, respaldo y soporte. El cifrado no sustituye la base jurídica de una transferencia internacional.
Biometría 2026-0039-R [21]	Norma firmada el 9/09/2026: considerar evaluación de impacto, necesidad/proporcionalidad, alternativas y revisión humana. Su vigencia depende de publicación en Registro Oficial; esta propuesta no certifica esa fecha.
Vulneraciones 2026-0040-R [22]	Norma firmada el 9/09/2026: incorporar al procedimiento de respuesta y verificar publicación, vigencia y obligaciones concretas de notificación. No fijar plazos por analogía con otro país.

Cómo se refleja en la arquitectura

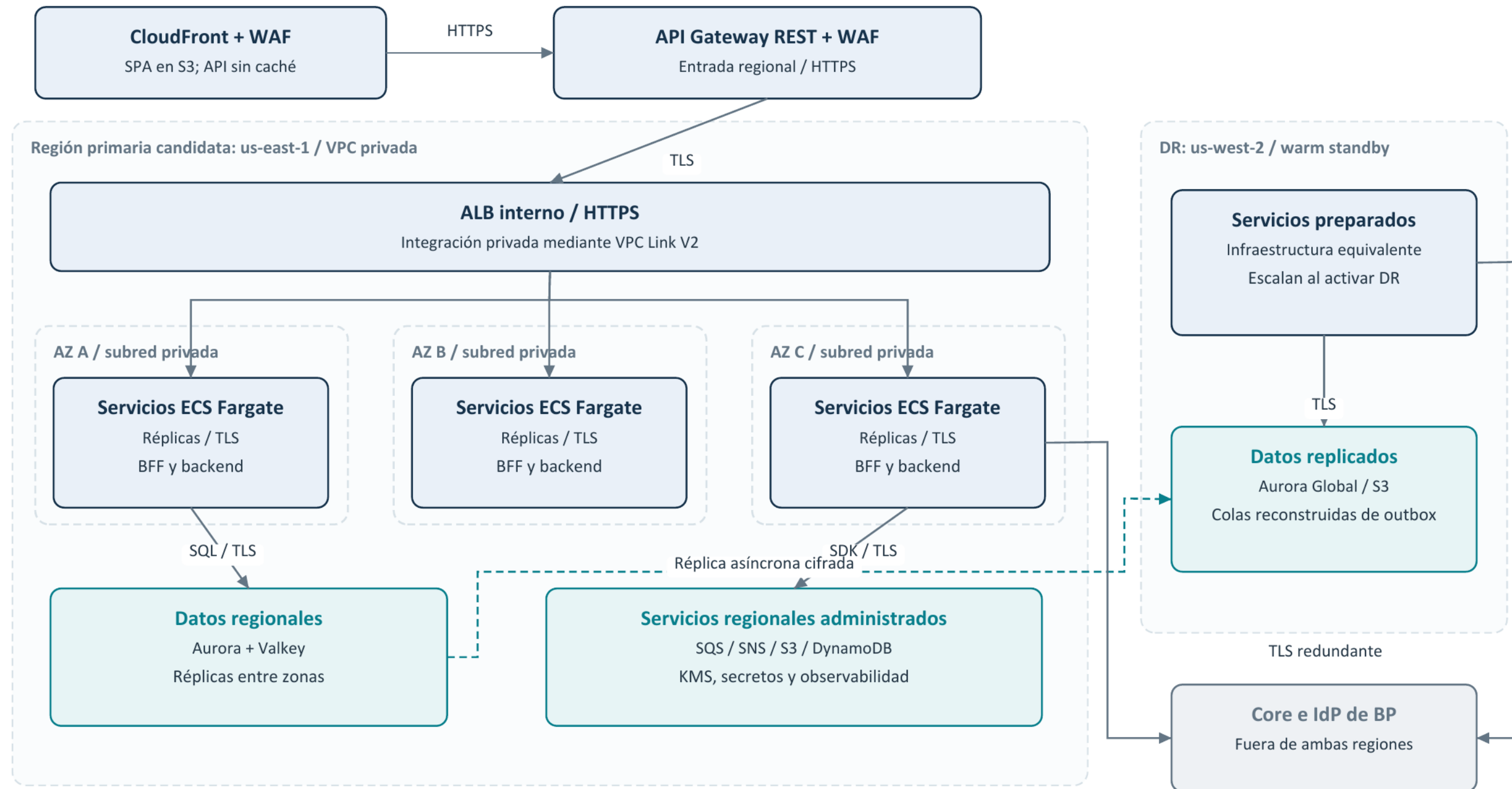
El expediente biométrico tiene acceso y ciclo de vida separados. Auditoría conserva referencias mínimas y una política de retención por tipo de evento. El DPD aprueba tratamiento y transferencias; Seguridad valida controles; Operaciones conserva evidencia de continuidad; Cumplimiento revisa obligaciones regulatorias y KYC/prevención de lavado aplicables a BP.

ISO 27001/27017/27018 y gestión de continuidad sirven de apoyo a los controles y a la evaluación de proveedores. PCI DSS sólo entra en alcance si se almacenan, procesan o transmiten datos de tarjetas; el caso descrito usa cuentas. GDPR no se asume aplicable automáticamente a una operación ecuatoriana.

La selección final de región queda condicionada a revisión legal, contractual y de latencia con el Core. El documento define controles de diseño; no emite una certificación de cumplimiento.

19 / Despliegue, HA y recuperación

AWS: tres zonas, servicios privados, datos redundantes y réplica regional. Regiones propuestas, no aprobadas.



Acceso a datos y servicios regionales desde las tres AZ. NAT por AZ y endpoints; enlace redundante al Core/IdP desde ambas regiones. La caché y las sesiones se reconstruyen.

Se propone us-east-1 como región primaria candidata y us-west-2 como recuperación, sujeto a autorización de transferencias internacionales, disponibilidad de servicios y medición desde Ecuador/Core. El plano regional administrado no equivale a una única zona. [10][11][12]

20 / Disponibilidad y recuperación

Objetivos medibles

Indicador	Objetivo y condición
Disponibilidad crítica	99,99 % anual de extremo a extremo: 52,56 minutos de indisponibilidad por año de 365 días. Medir acceso, consultas y envío/consulta de transferencias; el SLA de una pieza cloud no demuestra el resultado global. [19]
Latencia	Hipótesis: consulta p95 < 800 ms y aceptación durable p95 < 1,5 s bajo carga acordada. La liquidación interbancaria tiene su propio plazo; no se oculta dentro del tiempo de aceptación.
Fallo de zona	Tres réplicas iniciales por servicio crítico distribuidas en tres AZ, capacidad restante validada, ALB con health checks y reemplazo ECS. Objetivo de recuperación < 2 min, a demostrar con inyección de fallos.
Desastre regional	Warm standby: RTO objetivo <= 15 min y RPO técnico <= 1 min para datos del canal. La réplica asíncrona no garantiza RPO cero. Un evento de 15 min consumiría el 28,5 % del presupuesto anual.
Operaciones monetarias	Los asientos siguen en Core/red. Antes de habilitar escritura se concilian referencias, estados e idempotencia. Si no puede demostrarse consistencia, mantener consultas y bloquear nuevas órdenes.

Procedimiento de recuperación

1) Declarar incidente y cercar al escritor primario para impedir split-brain. 2) Medir retraso y promover la réplica autorizada. 3) Levantar capacidad, secretos y conectividad de la segunda región. 4) Reautenticar sesiones y reconstruir colas desde outbox y checkpoints. 5) Conciliar operaciones contra Core/red. 6) Probar recorridos sintéticos y cambiar tráfico. 7) Hacer retorno planificado con un único escritor.

Aurora replica datos entre regiones, pero las colas regionales no se copian automáticamente. Outbox, journal y el índice de entregas se replican; S3 tiene réplica entre regiones con retención compatible. Backups aislados y restauraciones periódicas cubren corrupción lógica. En ambos lados se prueba acceso al Core y al IdP.

La recuperación del canal depende de la continuidad de Core, IdP y red. Si sus contratos no soportan estos objetivos, se debe ajustar el diseño antes de prometer 99,99 %. Un RTO es una meta de recuperación, no disponibilidad garantizada.

21 / Monitoreo y operación

Señal	Alerta inicial y acción
Recorridos críticos	Pruebas sintéticas cada minuto y tasa de fallos por canal. Alertas por consumo acelerado del presupuesto de error; guardia identifica la dependencia y activa el runbook.
Transferencias	Edad de DESCONOCIDA/PENDIENTE, reversos y divergencias. Umbral operativo inicial de 2 min para incertidumbre local; el SLA del riel regula pendientes de liquidación. Escalar sin reenviar a ciegas.
Auditoría / outbox	Edad de evento más antiguo > 60 s y huecos de secuencia. Revisar almacenamiento, permisos y consumidor; bloquear acciones sin captura durable si el journal no admite más datos.
Notificaciones	Profundidad/edad de colas, rechazos y DLQ. Mensaje en DLQ genera incidente con dueño y replay controlado, después de corregir causa.
Datos / capacidad	Conexiones, locks, espacio, retraso de réplica, cache hit ratio, CPU y concurrencia. Escalar dentro del límite que soporte el Core; priorizar comandos financieros.
Seguridad	MFA fallido, BOLA, anomalías de acceso y cambio de privilegios. Correlación en SIEM con evidencias mínimas y procedimiento de respuesta.

Observabilidad y auto-recuperación

OpenTelemetry propaga correlationId/traceld; métricas, trazas y logs se consultan en CloudWatch y el SIEM corporativo. Auditoría de negocio conserva su ruta independiente. ECS reemplaza tareas no saludables y escala por CPU, solicitudes o edad de cola; no reinicia servicios sanos porque el Core esté lento.

Timeouts acotados y presupuesto de tiempo por llamada, circuit breaker y pools separados contienen fallos. Sólo se reintentan automáticamente lecturas e instrucciones con idempotencia comprobada, con backoff, jitter y máximo acordado. Un circuito abierto muestra indisponibilidad o pendiente, nunca éxito supuesto.

Operaciones mantiene guardia, runbooks y ejercicios de restauración trimestrales propuestos. Los despliegues canary observan latencia y errores; las migraciones usan expand/contract. El rollback de una versión no revierte movimientos contables.

22 / Capacidad y manejo de costos

Dimensionamiento explícitamente hipotético

Para comparar alternativas se usa una base de 100 solicitudes/s promedio, 500/s en pico y 80 % de consultas. No son datos provistos por BP. A 100/s durante 30 días resultarían 259,2 millones de solicitudes; este volumen hace material el costo de Gateway, logs y eventos, además del cómputo.

Partida	Método de cálculo y control
Fargate	Suma de horas de vCPU y GiB por tarea × tarifa regional. Ejemplo para el mínimo: 7 servicios × 3 tareas × 0,5 vCPU / 1 GiB = 10,5 vCPU y 21 GiB; sumar authorizer/publicadores y dimensionar con pruebas. [16]
Aurora / Valkey	Horas de nodos o capacidad + I/O + almacenamiento + réplica. Separar sesiones del caché; evitar duplicar el libro del Core. Reservar capacidad sólo después de medir uso estable.
API / eventos / auditoría	Llamadas y tamaño de eventos; retención caliente corta para búsqueda y archivo según política. No muestrear la auditoría obligatoria; sí ajustar el muestreo de trazas técnicas.
Notificación / biometría	Cantidad de SMS, correos y verificaciones × tarifa/país. Incluir reintentos, intentos fallidos, validación documental y revisión humana.
Red y continuidad	NAT por zona, datos inter-AZ e interregión, endpoints, conectividad al Core, backups y capacidad de DR. El sitio alternativo es un costo recurrente, no sólo de incidente.

Modelo de presupuesto

Costo mensual = cómputo + datos + API/mensajería + observabilidad + red + proveedores + DR + soporte. Construir escenarios base, pico y desastre con AWS Pricing Calculator y ofertas de proveedores. Sin tamaño de datos, contratos ni tarifas seleccionadas no se presenta una cifra total como cotización.

Etiquetas por servicio y ambiente, presupuesto con alertas al 80/100 %, revisión mensual de costo por cliente activo y por transferencia. Escalar trabajadores asíncronos según cola; no usar Spot para el mínimo transaccional. Limitar crecimiento del autoscaling a la capacidad probada del Core y de las bases.

La selección de ECS reduce tareas de operación frente a Kubernetes; no implica que siempre tenga menor factura. El dimensionamiento incluye capacidad superviviente tras perder una AZ.

23 / Decisiones y alternativas (I)

Cada decisión presenta dos fundamentos, alternativa y costo o condición. Son razonamientos del diseño propuesto.

Decisión	Fundamentos y alternativa
D1. Servicios por capacidad	1) Alta cohesión de reglas por dominio. 2) Aislamiento y escalado según consulta/escritura. Alternativa: monolito modular, más simple de operar; se descarta aquí por límites de integración y fallos independientes. Costo: llamadas remotas y observabilidad.
D2. Puertos y adaptadores	1) Inversión de dependencias protege las reglas del formato legado. 2) Sustitución y pruebas de proveedores por contrato. Alternativa: SDK directo desde controladores; acopla negocio y transporte. Costo: interfaces y traducción adicionales.
D3. Angular + BFF	1) Convenciones comunes para módulos y formularios. 2) El BFF reduce exposición de tokens al navegador. Alternativa: React y SPA OAuth directa. Costo: otro servicio y protección CSRF; BFF no elimina XSS.
D4. Flutter / MVVM	1) Presentación consistente en dos plataformas. 2) ViewModels y repositorios separan UI y acceso a datos. Alternativa: React Native. Costo: Dart e integración de SDK biométrico nativo.
D5. Code + PKCE / OIDC	1) El código queda vinculado al cliente iniciador. 2) Separa identidad de permisos y reutiliza el IdP. Alternativa: Implicit o recibir la contraseña en la app. Costo: validar capacidades y configurar clientes, sesión y renovación.
D6. Gateway y servicios privados	1) Centraliza protección y contratos de entrada. 2) Reduce exposición directa del backend. Alternativa: publicar cada servicio. Costo: latencia, cuotas y dependencia regional del Gateway.
D7. Java / Spring Boot	1) Tipos y límites transaccionales explícitos favorecen reglas financieras. 2) Separación de capas e inyección de dependencias facilitan pruebas por contrato. Alternativa: .NET o Node.js, igualmente viables con experiencia del equipo. Costo: memoria y ajuste del arranque.

24 / Decisiones y alternativas (II)

Decisión	Fundamentos y alternativa
D8. Aurora / esquemas propios	1) Atomicidad local entre estado y outbox. 2) Restricciones únicas y versionado para concurrencia. Alternativa: base por servicio desde el inicio, con más aislamiento y costo; o tablas compartidas, que acoplan cambios. Costo: el clúster sigue siendo fallo compartido.
D9. Cache-Aside	1) Reduce lecturas repetidas del perfil. 2) Puede perderse sin perder la fuente de verdad. Alternativa: consultar siempre al Core. Costo: datos temporalmente antiguos; TTL, invalidación y autorización fuera del caché.
D10. Outbox + pub/sub	1) Evita separar commit local y registro del evento. 2) Permite consumidores independientes. Alternativa: notificar dentro de la petición. Costo: consistencia eventual y duplicados; exige deduplicación.
D11. Saga e idempotencia	1) Evita bloquear dos sistemas con una transacción global. 2) Permite recuperar y conciliar estados parciales. Alternativa: 2PC o reintento ciego. Costo: compensaciones de negocio, estados inciertos y operación asistida.
D12. Índice + archivo bloqueado	1) El índice permite investigar rápido por cliente/operación. 2) Retención bloqueada protege evidencia frente a cambios administrativos. Alternativa: sólo logs técnicos. Costo: doble almacenamiento y reconciliación de integridad.
D13. ECS + múltiples AZ	1) Réplicas distribuidas contienen pérdida de zona. 2) Servicio administrado reduce operación de nodos. Alternativa: EKS si hay capacidades Kubernetes previas. Costo: tareas mínimas, cuotas y diseño de red.
D14. DR con un escritor	1) Evita conflictos financieros activos en dos regiones. 2) Réplica preparada acorta recuperación frente a sólo backups. Alternativa: active-active, de mayor complejidad, o recuperación en frío, más lenta. Costo: capacidad alterna y conciliación por réplica asíncrona.
D15. Plataforma AWS	1) Servicios administrados cubren cómputo, eventos y datos. 2) Una plataforma común limita fragmentación operativa. Alternativa: Azure, igualmente viable según experiencia y contratos. Costo: dependencia de proveedor y validación de regiones.
D16. Correo y SMS	1) Cubren canales de contacto complementarios. 2) Proveedores independientes reducen dependencia de una sola entrega. Alternativa: sólo push, insuficiente para el mínimo de sistemas definido aquí. Costo: tarifas variables y acuses dispares.
D17. Biometría administrada	1) Evita mantener un modelo de detección propio. 2) Un adaptador facilita evaluación y cambio de proveedor. Alternativa: KYC integral contratado. Costo: privacidad, integración nativa, validación de precisión y revisión humana.

25 / Trazabilidad de requisitos

Requisito	Evidencia en este documento
Consulta de datos, productos y movimientos	C2 de atención; C3 de consultas; secciones 05 y 15. Core y detalle separados.
Transferencias y pagos propios/interbancarios	C3 de transferencias, secuencia y estados: 07, 13 y 14.
SPA y móvil multiplataforma; alternativas	Sección 09 y decisiones D3-D4.
OAuth 2.0 con producto existente	Secciones 10-11. Code + PKCE, OIDC, BFF y autorización de recursos.
Onboarding facial y acceso posterior	C3 de soporte y sección 12; prueba de vida, activación y MFA/passkey.
Auditoría de acciones del cliente	C2 de soporte, sección 16 y D12; consultas, mutaciones y acceso.
Persistencia para clientes frecuentes	Sección 15 y D8-D9: repositorios, caché, invalidación y fuentes durables.
Dos sistemas de notificación	Sección 16: correo SES y proveedor SMS independiente, confirmación y reintentos.
API Gateway y tres servicios principales	C2 de atención, sección 05 y C3 de consultas/transferencias.
C4 hasta componentes e infraestructura	Contexto 02; contenedores 03-04; componentes 06-08; despliegue 19.
HA, fallos, DR, monitoreo, auto-healing	Secciones 19-21: tres AZ, recuperación, circuitos, colas y operación.
Normativa, seguridad y nube	Secciones 17-19: controles, Ecuador y revisión de regiones.
Decisiones justificadas y manejo de costos	Secciones 22-24: modelo de capacidad y 17 decisiones con dos fundamentos.
PDF y repositorio público	Este PDF constituye el entregable; publicar únicamente el documento en el repositorio autorizado y colocar su URL en la plataforma.

26 / Validación y condiciones de aceptación

Pruebas propuestas para una implementación futura. No se afirma que hayan sido ejecutadas en sistemas reales.

Escenario	Resultado que se debe demostrar
Doble envío concurrente	Misma clave y cuerpo devuelven un solo id de operación; sólo una instrucción financiera efectiva. Misma clave con otro cuerpo: 409.
Core confirma, canal pierde respuesta	DESCONOCIDA se concilia por referencia y termina con el resultado real. No aparece un segundo débito.
Rechazo interbancario	Reserva liberada o reverso confirmado; si falla la compensación permanece EN_REVERSO con alerta.
Repetición de evento	Un solo registro lógico por eventId; una intención de aviso por canal y estado. Duplicados externos se documentan si el proveedor carece de idempotencia.
Pérdida de zona / región	Medir recuperación, RPO y capacidad remanente. En DR demostrar fencing y conciliación antes de reabrir escrituras.
Cache vacía o caída	Consultas autorizadas llegan al origen con límites; ningún saldo almacenado autoriza una operación.
Auditoría o SMS indisponible	Captura durable o rechazo seguro; recuperación sin huecos. Movimiento confirmado conserva su estado aunque no se entregue el aviso.
Ataques de autorización	Otro cliente no puede leer una cuenta u operación; tokens vencidos/incorrectos, callback repetido y sesión de onboarding no autorizan banca.
Onboarding incompleto	Un resultado positivo enviado por la app no activa al cliente. Falla entre Core e IdP se reanuda sin duplicar altas.

Pendientes que bloquean producción

Confirmar idempotencia y estados de Core/red, exportación del IdP, base jurídica y retención, regiones, contratos de proveedores, latencia del enlace y volumen real. Validar integraciones y costos mediante una prueba controlada con datos sintéticos. No se garantiza el objetivo global si una dependencia crítica carece de continuidad compatible.

27 / Fuentes técnicas (I)

Referencias primarias. Consulta: 15 de septiembre de 2026. Los números entre corchetes remiten a estas fuentes; las decisiones y valores propuestos se identifican como tales.

[01] C4 model. Diagramas y niveles de abstracción

<https://c4model.com/diagrams>

[02] IETF. RFC 9700: OAuth 2.0 Security Best Current Practice

<https://www.rfc-editor.org/rfc/rfc9700.html>

[03] OpenID Foundation. OpenID Connect Core 1.0

https://openid.net/specs/openid-connect-core-1_0.html

[04] IETF. RFC 8252: OAuth 2.0 for Native Apps

<https://www.rfc-editor.org/rfc/rfc8252.html>

[05] W3C. Web Authentication, Level 2

<https://www.w3.org/TR/webauthn-2/>

[06] Angular. Descripción de la plataforma

<https://angular.dev/overview>

[07] Flutter. Recomendaciones de arquitectura

<https://docs.flutter.dev/app-architecture/recommendations>

[08] React Native. Componentes nativos

<https://reactnative.dev/docs/intro-react-native-components>

28 / Fuentes técnicas (II)

[09] AWS. Patrón Transactional Outbox

<https://docs.aws.amazon.com/prescriptive-guidance/latest/cloud-design-patterns/transactional-outbox.html>

[10] AWS. Integración privada de API Gateway REST

<https://docs.aws.amazon.com/apigateway/latest/developerguide/set-up-private-integration.html>

[11] AWS. Equilibrio de servicios ECS entre zonas

<https://docs.aws.amazon.com/AmazonECS/latest/developerguide/service-rebalancing.html>

[12] AWS. Aurora Global Database

<https://docs.aws.amazon.com/AmazonRDS/latest/AuroraUserGuide/aurora-global-database.html>

[13] AWS. S3 Object Lock

<https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html>

[14] AWS. Rekognition Face Liveness

<https://docs.aws.amazon.com/rekognition/latest/dg/face-liveness.html>

[15] AWS. Reintentos de entrega de SNS

<https://docs.aws.amazon.com/sns/latest/dg/sns-message-delivery-retries.html>

[16] AWS. Modelo de precios de Fargate

<https://aws.amazon.com/fargate/pricing/>

29 / Fuentes normativas

[17] Ecuador. Ley Orgánica de Protección de Datos Personales

<https://spdp.gob.ec/wp-content/uploads/2024/12/03.pdf.pdf>

[18] Ecuador. Reglamento General de la LOPDP

<https://spdp.gob.ec/wp-content/uploads/2024/12/04.pdf.pdf>

[19] Superintendencia de Bancos. Libro I, título IX, capítulo V: riesgo operativo

<https://www.superbancos.gob.ec/bancos/descargas/30300/>

[20] SPDP. Resolución 2026-0004-R: transferencias de datos

<https://spdp.gob.ec/resolucion-4/>

[21] SPDP. Resolución 2026-0039-R: datos biométricos

<https://spdp.gob.ec/wp-content/uploads/2026/09/SPDP-SPD-2026-0039-R.pdf>

[22] SPDP. Resolución 2026-0040-R: notificación de vulneraciones

<https://spdp.gob.ec/wp-content/uploads/2026/09/SPDP-SPD-2026-0040-R.pdf>

[23] SPDP. Registro de resoluciones

<https://spdp.gob.ec/resoluciones2/>

El capítulo de riesgo operativo se obtuvo desde el vínculo de la codificación oficial de la Superintendencia de Bancos. Las resoluciones SPDP de septiembre de 2026 se identifican por fecha de firma; su publicación en Registro Oficial debe corroborarse antes de establecer vigencia y plazos exigibles.